

Liivv — IT meeting glossary

Who this is for: you, before the next architecture / security meeting

In the room: **We** = Liivv (you: the app and the BigCommerce store). **IT** = the team reviewing it. The pack does not split Engineering / Ops / Legal.

What this is not: the IT pack. The IT pack is [Liivv-Architecture.md](#) / [PDF](#). This sheet only explains the **words**.

Contents

§	Section	Job
1	The whole architecture in plain English	The picture, out loud, once
2	Sentences to have ready	What to say when they ask
3	Must-know first	Words to learn before the meeting
4	Full glossary (A–Z)	Lookup during the meeting
5	IT requirement → Liivv	Their box → our box, one line
6	Gaps in spoken English	How to admit G1 / G5 without rambling
7	Words they may throw that are not in the pack	Do not invent a control for these
8	10-minute drill	Night-before practice

If you only remember five things: **browser has no database key**, **Next.js is the only talker**, **PHI is in Canadian Supabase**, **shop is BigCommerce**, **secrets are Vercel encrypted env vars**.

1. The whole architecture in plain English

IT's usual picture: people use a website, the website talks to a **gateway**, the gateway talks to **small services**, those services talk to a **SQL database inside Azure**. On the side: company login (**Entra**), a password locker (**Key Vault**), build pipeline (**CI/CD**), and security scanners (**Veracode / Sonar / CrowdStrike**). Those are **IT requirements**. Liivv is the **same idea**, different house:

- Shoppers and staff use a website.
- That website **is** the app and the API (one Next.js program on **Vercel**).
- There is **no** Azure gateway product and **no** mesh of microservices.
- Data does **not** sit in Azure SQL next to the app. Shop data is **BigCommerce**. Health data is **Canadian Supabase**. Cards are **Stripe** (we never keep the card number).
- Login is **BigCommerce** for shoppers. Pharmacists: **BC admin iframe** + **shared password** (Vercel encrypted env). Entra needs IT to provide a connection.
- Secrets sit in **Vercel encrypted env vars** — required to host on Vercel. That is our vault.
- We do **not** run Veracode / Sonar / CrowdStrike in this pipeline.

The sentence IT cares about: the shopper's browser is not allowed to talk to the database. Only the server is. If someone steals the **server** secret, row rules will not save you — that is also true when an Azure API uses a privileged SQL login. That leftover risk is called **residual**.

2. Sentences to have ready

Say these in your own words. Do not invent extra controls.

If they say...	You can say...
"Does the browser talk to the database?"	"No. The browser talks to Next.js on Vercel. Next.js is the only process that holds the database and payment secrets."
"Where is PHI?"	"Canadian Supabase. Not BigCommerce. Not Vercel as a database. Cards are Stripe — we never store PAN."
"Where is the shop data?"	"BigCommerce is the system of record for catalog, cart, checkout, orders, and customer login."
"Do you have Entra / SSO / MFA?"	"Entra needs IT to approve and give us a connection — that's G1. Until then shoppers use BigCommerce login. Pharmacists open Liivv Staff inside BC admin, then a shared username/password in Vercel encrypted env."
"Where is Key Vault?"	"In place on this host: Vercel encrypted env vars. We have to put secrets there to host. That closed G2."
"Where is the API gateway / APIM / WAF?"	"In place: Liivv API gateway on every /api call, plus Liivv action gateway (runCustomerAction / runStaffAction) for PHI form posts. That closed G4."
"How do you scan the code?"	"Lint and typecheck in CI. We do not have Veracode, Sonar, or CrowdStrike in this pipeline. That's gap G5."
"What if someone fakes a Stripe webhook?"	"We verify the Stripe signature with the webhook secret. Same idea for BigCommerce — Bearer secret."
"Can a shopper read everyone's health records?"	"There is no database key in the page. RLS is on with no anon policies. The server uses the service role only after a login check."
"What if Stripe / Supabase / BigCommerce is down?"	"We do not fail over. That is not backup/RPO (G9). BigCommerce down: store unavailable; Stripe still charges renewals and we retry the shop order on <code>invoice.paid</code> for about three days. Stripe down: shop and cart stay up, new checkout cannot pay, cart is kept; Subscribe is hidden ; Stripe still bills existing cards when they are back. Supabase down: shop and one-time checkout stay up; subscriptions and curated cart kits are disabled (<code>cart_subscription_lines</code> / <code>cart_kit_sessions</code>); health/pharmacy/chat show a notice. Vercel down: whole site down; Stripe still charges and retries the webhook when we are back."

Do not volunteer: a future move to Azure. If they ask about the AI assistant: it **remains off (S4)**; we can use IT resources later if we decide to implement it. If they ask about gaps, point at remaining open items (**G1, G5**).

Closed: **G2, G3, G4, G6, G7, G8, G9, G10.**

3. Must-know first (learn these)

App and hosting

Word	In English	Liivv
Next.js	The website program (React pages + server).	Our whole app. Version 16. Lives in core/.
Vercel	The company that hosts the Next.js app (like Azure App Service, but not Azure).	Hosting only — not where we store shop or health records.
Node / runtime	The engine that runs the server JavaScript.	One Node process: page + API together.
Serverless instance	A small copy of the app that Vercel starts to handle traffic. There can be many at once.	/api rate limit is one shared counter (Vercel Runtime Cache), not per copy.
Preview vs Production	Production = the live Vercel site. Local preview = Cursor / <code>.env.local</code> .	Only production keys on Vercel. We do not use Vercel Preview (closed G3).
Env vars / secrets	Passwords and API keys stored as settings, not in the public code.	Vercel encrypted env + gitignored <code>.env.local</code> . Required to host on Vercel.
NEXT_PUBLIC_...	A key that is allowed in the browser.	Only Stripe's publishable key. Database keys must never be NEXT_PUBLIC.

The three data houses

Word	In English	Liivv
System of record	The official owner of that kind of data. Other systems may copy it; this one is the source.	Shop → BigCommerce. Health → Supabase. Cards → Stripe.
BigCommerce (BC)	The store engine: products, cart, checkout, orders, customer login, most email.	Shoppers log in here. Pharmacists open Liivv Staff inside BC admin (iframe), then shared password.
Supabase	Hosted Postgres database (SQL) with extra tools. Ours is in Canada (ca-central-1).	PHI: profile, insurance, prescriptions, CarePack, care chat.
Stripe	Card payments and subscriptions.	PAN / CVC never stored in Liivv. We use Stripe Elements (their form, not ours).
Vendor / SaaS	Someone else's cloud product we call over the internet, not a server in our Azure subscription.	BC, Supabase, Stripe, Vercel. An Azure SQL next to the app would be in-estate . Ours is vendor.

Identity and access

Word	In English	Liivv
Identity	How we know who you are.	Customers: BC login. Pharmacists: BC iframe load + shared username/password at /pharmacy-admin/login.
SSO	Single sign-on: one company login unlocks many apps.	Entra needs IT to connect it. Liivv today: BC shopper login + shared pharmacist login.
MFA	Extra step besides password (app, SMS, hardware key).	Not Entra (G1). Not on the pharmacist login. Not shoppers.
Entra (Microsoft Entra ID)	Microsoft's work identity (old name: Azure AD).	Needs IT to approve and provide a connection. G1 .
Session	Proof you already logged in (usually a cookie).	Auth.js for customers. Pharmacists: liivv_pharmacy_admin + liivv_pharmacist.
JWT	A signed blob of claims (who you are, cart id, expiry). Tampering breaks the signature.	Customer session, anonymous cart, some BC login flows.
OAuth	A standard "this app is allowed to act for this store / user" handshake.	How the Liivv Staff app is installed on the store.
Load token / signed payload	BC JWT when the control panel opens the embedded app.	Verified on /api/bigcommerce/app/load; sets liivv_pharmacy_admin. Then shared pharmacist login.
iframe	A page inside another page.	Pharmacist admin runs inside BC admin as an iframe (/pharmacy-admin).

Protection on the wire and at the API

Word	In English	Liivv
HTTPS / TLS	Encrypted pipe on the internet. HTTPS is HTTP over TLS.	Browser → Vercel, and Vercel → vendors.
API	A machine interface: "do this / give me that," not a human webpage.	Next.js /api/* and server actions . Also BC, Stripe, Supabase APIs.
API gateway / APIM	A dedicated front door that checks auth, rate limits, and routes to many services. Azure's product is API Management .	Liivv API gateway — Azure APIM equivalent in this app. Every /api/* hits it first. PHI form posts use the Liivv action gateway (runCustomerAction / runStaffAction), not /api.
WAF	Web application firewall: filters hostile HTTP traffic.	No separate WAF product. Vercel edge + our gateway routes.
Trust boundary	The line between "untrusted internet" and "code that holds secrets."	Browser and webhook callers are untrusted. Next.js is the secret holder.
Service role	The god key for Supabase. It bypasses RLS .	Server only. Never in the browser. Same idea as a privileged SQL login on an API.

Word	In English	Liivv
RLS	Row Level Security: SQL rules that hide other people's rows.	On , with no anon/authenticated policies (deny by default). Does not stop the service role.
Webhook	They call us when something happened (payment succeeded, product changed).	Must verify Stripe signature / BC Bearer secret or anyone could fake it. Stripe retries ~3 days on 5xx. We retry placing the BC order on those <code>invoice.paid</code> retries (\$4).
Bearer token	"Authorization: Bearer \<secret\>" — possession of the string is the proof.	BC product webhooks.
Rate limit	Cap how often one IP can call something.	Every <code>/api</code> : 120/IP/min shared counter . DPD also 60.
Proxy	Our server fetches an external API so the browser never talks to it directly.	Medication search → Health Canada DPD.
CSP	Content Security Policy: browser rules for which scripts/frames are allowed.	<code>/pharmacy-admin</code> allows BigCommerce to frame it.

Data words IT will use

Word	In English	Liivv
PHI	Protected / personal health information: health + who they are.	Insurance, Rx, CarePack, care chat — Supabase only .
PII	Who they are: name, email, address, customer id.	BigCommerce + Supabase profiles.
PAN / CVC	Card number / security code.	Never stored . Stripe handles the card.
SQL / Postgres	The database language / the database engine Supabase uses.	Canadian Postgres. Not Azure SQL.
Catalog	Product list (and for DPD, the drug list).	Shop catalog = BC. Drug catalog = Health Canada DPD (not PHI).
GraphQL vs REST	Two API styles. GraphQL = one query shape. REST = URLs + HTTP verbs.	Storefront GraphQL for the shop. Admin REST to create orders after Stripe.
PIPEDA / PHIPA	Canadian privacy (federal) / Ontario health privacy.	The privacy frame we cite.
HIPAA	US health privacy law.	Do not claim HIPAA . We listed a Canadian region.
DPA / BAA	Contracts with vendors about personal / health data.	In place (closed G8).
RPO	Recovery Point Objective: how much data you can afford to lose in a restore.	Supabase daily backups + restore steps in \$4 (S2 notes). Closed G9 .

Word	In English	Liivv
RTO / degraded mode	How fast the *service* is usable again; or keep working with a subset.	In place on the storefront: notice instead of a 500; remaining vendors still work. Supabase down also disables subscriptions and curated cart kits . No second-site failover. Full per-system behavior (shopper + renewals) is \$4 . Not G9.

IT requirement side boxes (mostly gaps)

Word	In English	Liivv
Key Vault	Azure's locker for secrets, with access logs and rotation.	On Vercel: encrypted env vars . That is how this host stores secrets.
CI/CD	Continuous Integration / Delivery: git push → tests → deploy.	GitHub → Vercel production . Local preview in Cursor. Lint + typecheck.
SAST	Static Application Security Testing: scanners that read source for bugs (e.g. Sonar, Veracode static).	Not the same as CrowdStrike (endpoint). All three named tools: not in this pipeline — G5 .
App Insights / OpenTelemetry	Azure (or standard) telemetry: traces, metrics, logs.	Vercel logs, Analytics, Speed Insights, an OpenTelemetry hook — not Azure Monitor.
Microservices	Many small services instead of one app.	We have one Node runtime. Simpler, not a mesh.
In the estate	Inside the company's own cloud subscription (typically Azure).	Liivv data is at vendors , reached over TLS.
Residual (risk)	The risk left after controls.	Stolen server secrets. Say this; don't claim zero risk.

4. Full glossary (A–Z)

Admin REST — BigCommerce's staff/admin HTTP API. Used **after** Stripe succeeds to create the official order. Needs `BIGCOMMERCE_ACCESS_TOKEN` (server only).

Allowlist (network) — "Only these IPs may connect to **Postgres / pooler**." Supabase can do that. Liivv's app path is **HTTPS** (PostgREST), which those restrictions **do not** cover. We rely on no browser key + RLS for the real path. Closed **G6** (see **\$4** S1 notes).

Anon / anonymous — Not logged in. Anonymous cart uses a **signed JWT** with the cart id, not a database key. RLS has **no** anon policies, so a stolen browser path should not read tables.

App Router — Next.js's current way of organizing pages and server code (`core/app/...`).

App Insights — Azure's application monitoring product. An IT requirement we do not have. We have Vercel's logging stack instead.

Auth.js (NextAuth) — The login library. For customers it talks to BigCommerce and sets a session cookie.

Azure — Microsoft's cloud. Liivv **today** does not run there. Do not describe a future Azure move unless that is the meeting's topic.

/pharmacy-admin — Pharmacist admin **inside** the BigCommerce control panel (iframe). Load sets `liivv_pharmacy_admin`; then `/pharmacy-admin/login` for the shared password.

Bearer — See Bearer token in §3.

Bypass (RLS) — The service role ignores row rules. By design. That is why the key must never ship to the browser.

ca-central-1 — AWS region name for Canada (Central). Where our Supabase project lives.

CarePack — A Liivv pharmacy/care request type stored in Supabase, worked by pharmacists in `/pharmacy-admin`.

Catalyst — BigCommerce's Next.js storefront starter. This repo is a Catalyst app plus Liivv health/pharmacy.

CI/CD — See §3.

Client secret (Stripe) — A short-lived token the **browser** uses with Stripe.js to confirm a payment. Not our database key. Different from `STRIPE_SECRET_KEY` (server).

Connection string — The full database URL + password. Must not appear in JavaScript sent to the shopper.

ConstructEvent — Stripe's method that checks the webhook signature. If it fails, we must not create an order.

Control panel — BigCommerce's admin UI. Pharmacist admin is a **separate Liivv page**, not an app inside that panel.

Cookie — Small data the browser stores and sends back. Ours include the customer session, anonymous cart, pharmacist `liivv_pharmacy_admin` + `liivv_pharmacist`.

CrowdStrike — Endpoint / runtime security (EDR). **Not** a SAST code scanner. We do **not** have it in this repo's pipeline (**G5**).

CSP — See §3.

CVC — Card security code. Never stored.

DACPAC — Azure SQL database deployment package. Typical Azure pipeline. We don't deploy SQL that way; schema lives in Supabase SQL files.

Deny by default — If no RLS policy allows a row, the query gets nothing. Our anon/authenticated roles have **no** policies.

DIN — Drug Identification Number (Health Canada). Comes from DPD. Stored with the prescription in Supabase after the customer picks it.

DPA — Data Processing Agreement with a vendor. **In place** (closed **G8**).

DPD — Health Canada Drug Product Database. **Free public** drug catalog API. No PHI. We **proxy** it. Prescription **copy** is saved in Supabase.

Edge — Servers close to the user. "Vercel edge" = their front network, not our database.

Egress — Outbound IP of our hosting when we call vendors. Optional Postgres allowlist needs **Vercel Static IPs** first (see §4 S1 notes / closed **G6**).

Elements (Stripe) — Stripe's card input widget. Card data goes to Stripe, not our server disk.

Encryption at rest — Disks encrypted in the vendor's cloud. We do **not** spell this as a Liivv-owned control in the pack; don't claim it unless a vendor contract says so.

Env / environment variable — See §3.

Estate — The company's owned cloud. Azure SQL next to the app would be in-estate. Ours is not.

Fax / transfer — How Rx images are handled: **not** uploaded as a photo dump into Liivv. Transfer or doctor fax only.

Gateway — See API gateway.

GitHub — Where the source code lives. Push → Vercel deploy.

Gitignore — Files Git will not commit. `.env.local` must stay gitignored.

GraphQL — See §3.

Health Canada — Public DPD API. Catalog only.

Hosting — Where the **program** runs (Vercel). Different from **system of record** (where **data** lives).

HTML / JS — The page and scripts the browser gets. Must not contain service keys.

IdP (identity provider) — The system that authenticates people. IT requirement: Entra. Liivv: BigCommerce for shoppers; shared pharmacist login for Rx/chat admin.

iframe — See §3.

In place / not in place — Honest status in the pack. "Have" or "equivalent" vs listed **gaps**.

Instance — See serverless instance.

JWT — See §3.

Key Vault — See §3.

Least privilege — Each secret/role can do only what it must. Service role is **not** least privilege on the database (it bypasses RLS). We limit **who can call** it (server after session), not what the key can do.

Lint / typecheck — Automatic checks (style and TypeScript types) before/during deploy. Not the same as Veracode.

Load token — See §3.

Logging / observability — Seeing errors and traffic. Vercel logs + Analytics + Speed Insights. Care-chat **message bodies are not** written to those logs (closed **G10**; pack §4).

Makeswift — Visual CMS from Catalyst. **Not used** on Liivv today (maybe later). Do not treat it as part of the live security story.

Microservices — See §3.

MFA — See §3.

Mitigation — What reduces a risk. For residual server-secret theft: secret hygiene, rotation, production-only keys on Vercel — **not** “RLS makes us safe.”

Next.js — See §3.

Node — See §3.

OAuth — See §3.

Olivia — The in-app care assistant **flag**. It is **off** (VIRTUAL_CARE_BOT_ENABLED) and **remains off (S4)**. We can use IT resources later if we decide to implement it. Human chat still lives in Supabase via /pharmacy-admin.

OpenTelemetry — A standard for traces/metrics. There is a **hook** in the stack, not Azure App Insights.

Order of record — The official order. **BigCommerce**, created after Stripe says payment succeeded.

PAN — Primary Account Number (the card number). Never stored in Liivv.

Payload — The body of a webhook or API call.

PCI — Card-industry security standard. We keep PAN out by using Stripe. Don’t claim a PCI audit unless we have one.

PHI / PII / HIPAA / PIPEDA — See §3.

Postgres — See §3.

Preview — See Preview vs Production.

Privileged SQL login — A powerful database user used by an API. Our equivalent is the Supabase **service role**.

Production — The live site.

Proxy — See §3.

Publishable key — Stripe key that **may** be in the browser. Still not a database key.

Rate limit — See §3.

Residual — See §3.

REST — See GraphQL vs REST.

RLS — See §3.

RPO — See §3.

RSC — React Server Components: HTML built on the server. Shopper gets HTML, not the service role.

Runtime cache — Short-lived memory on Vercel during checkout (snapshot), not the system of record.

SAST — See §3.

Secret hygiene — Don’t commit keys, don’t put them in the browser, only upload production keys to Vercel, rotate if leaked.

Server action — Next.js function that runs **on the server** when the UI submits something (profile, Rx). Not a public URL you casually call, but still server-side.

Server-only — A module that Next.js will not bundle into browser JavaScript. Our Supabase client is server-only.

Service role — See §3.

Session — See §3.

Signed — Cryptographically sealed so tampering is detectable (JWT, Stripe webhook).

Sonar (SonarQube) — Code-quality / security scanner. Not in our pipeline. **G5**.

SQL — Database language. “Walk into a database with a key from the page” = the failure mode we are scoring.

SSO — See §3.

Store hash — BC identifier for **this** store. Staff app session is bound to it so another store’s token should not work.

Storefront API / Storefront GraphQL — The shop-facing BC API (catalog, cart) using the storefront token — still **server-side** in our app.

Stripe.js — Stripe’s browser library. Confirms the payment; we never see PAN.

Supabase — See §3.

TLS — See HTTPS / TLS.

Transactional email — Order/account mail. Sent by **BigCommerce**, not a custom Azure mail microservice.

Trust boundary — See §3.

Typecheck — TypeScript compiler check in CI.

Vault — Generic word for a secrets locker. On this host = Vercel encrypted env.

Vendor DB — Database we don’t host ourselves (Supabase). Contrast: in-estate SQL.

Veracode — Commercial AppSec platform (includes SAST and more). An IT requirement we don’t have. **G5**.

Vercel — See §3.

WAF — See §3.

Webhook — See §3.

.env.local — Local secret file on a developer machine. Gitignored. Production secrets are Vercel encrypted env.

5. IT requirement → Liivv (one line each)

Use this when they walk the checklist.

IT requirement	One-line Liivv
Web app	Next.js 16 on Vercel (shop, account dashboard, pharmacist admin).
API gateway	In place. Liivv API gateway on every /api/* plus action gateway for PHI posts (closed G4).
Microservices	One Node runtime.
SQL in the estate	Canadian Supabase + BigCommerce + Stripe. Vendor, not Azure SQL.
Entra SSO / MFA	Shopper login is BigCommerce. Pharmacist admin is BC iframe + shared password in Vercel env. Entra needs IT approval (G1).
Secrets / vault	In place. Vercel encrypted env vars (closed G2).
Rate limiting	In place. Every /api 120/IP/min shared counter; DPD also 60 (closed G7).
Webhook auth	Stripe signature; BC Bearer.
CI/CD	GitHub → Vercel. Not GitHub Enterprise + DACPAC.
Veracode / Sonar / CrowdStrike	Not in this pipeline (G5).
App Insights	Vercel logs / Analytics — not Azure Monitor.
Email microservice	BigCommerce mail.

6. Gaps in spoken English

These are **ours to address**, not embarrassments to hide. **G2, G3, G4, G6, G7, G8, G9**, and **G10** are **in place** — do not list them as missing.

ID	Say it like this
G1	Entra needs IT approval. We cannot turn it on ourselves. Shoppers: BigCommerce. Pharmacists: BC iframe + shared password in Vercel encrypted env.
G2	In place. Vercel encrypted env vars are the vault on this host.
G3	In place. Only production keys on Vercel. No Vercel Preview — we preview locally in Cursor.
G4	In place. Liivv API gateway on every /api/* plus Liivv action gateway for PHI / staff form posts.
G5	No Veracode, Sonar, or CrowdStrike in this repo's pipeline. IT: say if those scanners are required.
G6	In place. App uses HTTPS to Supabase — Postgres IP allowlist does not cover that path. No browser key + RLS protect the real path (\$4 S1 notes).
G7	In place. /api rate limit is one shared counter in Vercel Runtime Cache (120/IP/min; DPD also 60).
G8	In place. Vendor DPAs/BAAAs are taken care of.

ID	Say it like this
G9	In place. Supabase daily backups + restore steps (\$4 S2 notes). That is restore after data loss, not “keep the store up if a vendor is down.”
G10	In place. We do not log care-chat bodies (or appointment free-text) to Vercel logs (\$4).

How the pack sections fit: **\$2** = map. **\$3** = open gaps (**G1**, **G5**). **\$4** = already defended. Then systems / flows. Closed gap IDs: **G2**, **G3**, **G4**, **G6**, **G7**, **G8**, **G9**, **G10**. **S4** (AI) is **Off**, not a G gap.

7. Words they may throw that are not in the pack

If they use these, don't fake a Liivv control. Ask what they need, or park it as a follow-up.

They say	Plain English	Safe response
Attack surface	All the ways someone can try to get in.	“Public surface is Next.js on Vercel plus verified webhooks. Database is not exposed to the browser.”
Zero trust	Don't trust the network; prove every hop.	“We don't claim a zero-trust product. Browser is untrusted; server holds secrets.”
Encryption in transit / at rest	TLS on the wire / encrypted disks.	“In transit: HTTPS/TLS to Vercel and vendors. At rest: vendor-side — we don't assert extra Liivv crypto in the pack.”
PIM / PAM / JIT access	Extra approval to use admin secrets.	“Not in this app pack. Secrets are Vercel encrypted env.”
Pen test / DAST	Humans or tools attacking the running site.	“Not claimed. Veracode / Sonar / CrowdStrike are G5 . We can take a testing requirement as a follow-up.”
SIEM / SOC	Central security log dump / 24h team.	“We have Vercel logs. Not Azure Sentinel / a SOC in this pack.”
Data residency / sovereignty	Data stays in-country.	“PHI is Canadian Supabase (ca-central-1). Shop data is BigCommerce (their regions). Don't over-claim BC residency unless we have that in writing.”
PCI-DSS	Card-data rules.	“PAN never stored; Stripe Elements. Don't claim a PCI certification unless we have one.”
Penetration of the supply chain	Attack via npm/GitHub.	“CI is GitHub → Vercel. Veracode / Sonar / CrowdStrike not in this pipeline (G5).”
IdP-initiated SSO	Login starts at Entra, then into the app.	“Not wired (G1).”

8. 10-minute drill (night before)

Cover the page. Answer out loud.

1. What is the only process that holds the Supabase service role?
2. Where does PHI live? Where do orders live? Where do card numbers live?
3. What is Entra, and do we have it?
4. What is Key Vault, and what do we use instead?
5. What is an API gateway, and what is our equivalent?
6. What does RLS **not** stop?
7. How do we know a Stripe “payment succeeded” call is really Stripe?
8. How do pharmacists get into pharmacist admin?
9. Name open gaps you will admit without being pushed.
10. What is residual risk in one sentence?

Answers: (1) Next.js on Vercel. (2) Canadian Supabase; BigCommerce; nowhere in Liivv — Stripe. (3) Microsoft work login; needs IT to connect — **G1**. (4) Azure secret locker; we use Vercel encrypted env — **in place** (closed **G2**). (5) Liivv API gateway on every `/api/*`, plus action gateway on PHI form posts — **in place** (closed **G4**). (6) A caller using the service role. (7) Signature + `STRIPE_WEBHOOK_SECRET`. (8) Open Liivv Staff from BigCommerce admin (iframe), then shared username/password at `/pharmacy-admin/login`. (9) **G5** (scanners) or **G1** (Entra) are fine; G6/G9/G10 are closed. (10) If the **server** secret is stolen, database row rules won’t stop that caller.

PDF of the IT pack: [Liivv-Architecture.pdf](#)

This glossary PDF: [Liivv-Architecture-Glossary.pdf](#)